Bloque 1: Introducción, Gobernanza y el Ciclo de Desarrollo Seguro

FADENA

Arquitectura Zero Trust y Marcos Corporativos

Ing. Roxana Quiroga Sollinger

Arquitectura Zero Parte 2

Módulo 2: Arquitectura Zero Trust y Marcos Corporativos

2.1 Arquitectura y gobierno Zero Trust

2.2 Microsoft Security Development Lifecycle

2.3 Seguridad en DevSecOps

Módulo 1: Fundamentos de Seguridad en el Software

FADENA

Arquitectura y Gobierno Zero Trust

2.1 Arquitectura y Gobierno Zero Trust

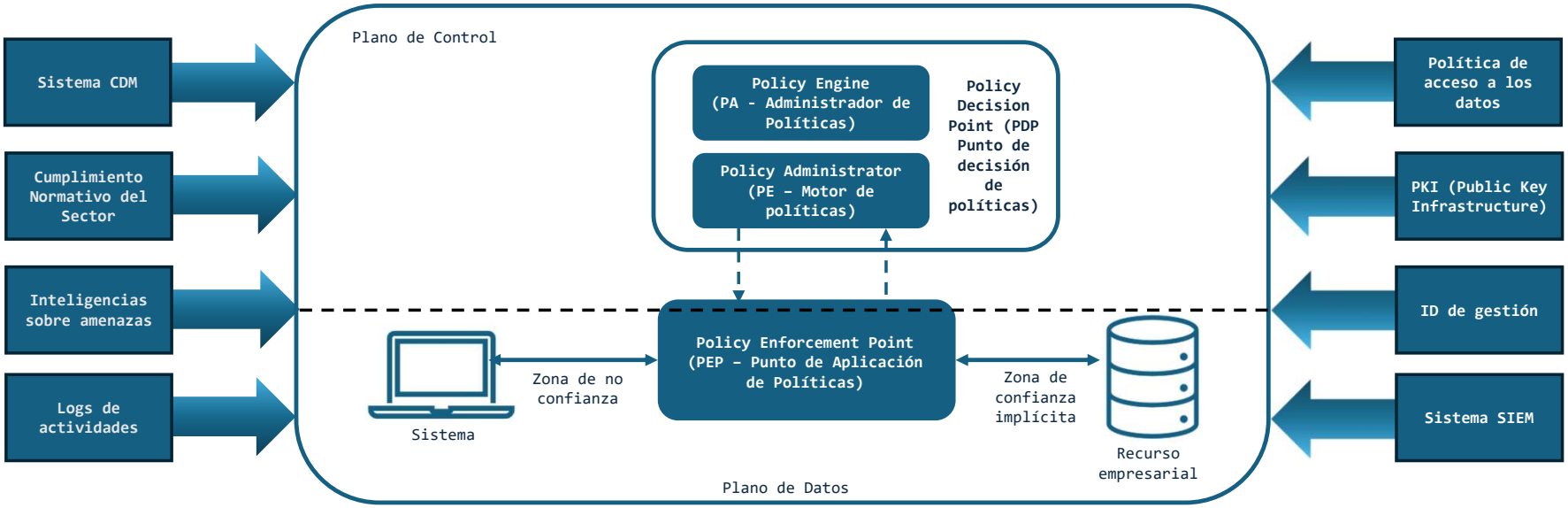
FADENA

- Definiciones
- Zero Trust (ZT)
- Gobierno Zero Trust (ZTG)
- **Arquitectura Zero Trust (ZTA)**
- **Amenazas**

2.1 Arquitectura y Gobierno Zero Trust

Arquitectura Zero Trust (ZTA)

Componentes Lógicos de ZTA



FADENA

2.1 Arquitectura y Gobierno Zero Trust

Arquitectura Zero Trust (ZTA)

Definición de los Componentes Lógicos de ZTA

PE – Motor de Políticas

Es el responsable de la decisión final sobre otorgar acceso a un recurso para un sujeto determinado. El motor de políticas utiliza la política empresarial, así como información de fuentes externas como entrada para un algoritmo de confianza para otorgar, denegar o revocar el acceso al recurso.

PA – Administrador de Políticas

Este componente se encarga de establecer y/o cerrar la ruta de comunicación entre un sujeto y un recurso (mediante comandos a los PEP correspondientes). Genera la autenticación específica de la sesión y el token o credencial de autenticación que un cliente utiliza para acceder a un recurso empresarial.

PEP – Punto de Aplicación de Políticas

Se encarga de habilitar, supervisar y, finalmente, finalizar las conexiones entre un sujeto y un recurso empresarial. El PEP se comunica con el PA para reenviar solicitudes y/o recibir actualizaciones de políticas.

FADENA

2.1 Arquitectura y Gobierno Zero Trust

Arquitectura Zero Trust (ZTA)

Fuentes de datos que proporcionan información y reglas de políticas

Sistema CDM

Sistema de diagnóstico y mitigación continua (CDM). recopila información sobre el estado actual del activo empresarial y aplica actualizaciones a la configuración y a los componentes de software.

Políticas de Acceso de Datos

Se refieren a los atributos, reglas y políticas que rigen el acceso a los recursos de la empresa. Estas políticas constituyen el punto de partida para autorizar el acceso a un recurso.

Cumplimiento Normativo

Este sistema garantiza que la empresa cumpla con cualquier normativa incluyendo todas las políticas que la empresa desarrolle para garantizar el cumplimiento.

Public Key Infrastructure

Este sistema se encarga de generar y registrar los certificados emitidos por la empresa para recursos, sujetos, servicios y aplicaciones. Este incluye el ecosistema global de autoridades de certificación.

Inteligencia sobre amenazas

Proporcionan información de fuentes internas o externas que ayudan al motor de políticas a tomar decisiones de acceso.

Sistema de Gestión de IDs

se encarga de crear, almacenar y gestionar las cuentas de usuario y los registros de identidad de la empresa. Contiene la información necesaria del usuario y otras características del mismo (rol, recursos asisgnados).

Logs de red y de sistemas

Se refiere a los registros de activos, tráfico de red, acciones de acceso a recursos y otros eventos que proporcionan información casi en tiempo real sobre el estado de seguridad de los sistemas de información.

SIEM

Sistema de gestion de información y eventos de seguridad. Recopila información centrada en la seguridad para su posterior análisis.

FADENA

2.1 Arquitectura y Gobierno Zero Trust

Arquitectura Zero Trust (ZTA)

Requisitos de Red para soportar ZTA

Conectividad de Red Básica

La red de área local (LAN), controlada o no por la empresa, proporciona enrutamiento e infraestructura básicos.

Seguridad de Dispositivos

La empresa debe poder distinguir entre los activos que posee o gestiona y el nivel de seguridad actual de los dispositivos.

Observar Tráfico de Red

Registra los paquetes detectados en el plano de datos, aunque no pueda realizar la inspección de la capa de aplicación en todos los paquetes.

Acceso autenticado y autorizado

Los recursos empresariales no aceptan conexiones entrantes arbitrarias desde internet.



Acceso al PEP

Los activos empresariales pueden acceder al componente PEP (Punto de Aplicación de Políticas)

Acceso al PA limitado por PEP

El PEP (Punto de Aplicación de Políticas) es el único componente que accede al administrador de políticas como parte de un flujo de negocio.

Acceso a Servicios Empresariales

Los usuarios remotos de la empresa deberían poder acceder a los recursos empresariales sin necesidad de atravesar primero la infraestructura de red de la empresa.

Infraestructura Escalable

La infraestructura utilizada para respaldar el proceso de decisión de acceso a ZTA debe ser escalable para adaptarse a los cambios en la carga de trabajo.

Accesos limitados

Es posible que los recursos de la empresa no puedan acceder a ciertos PEP (Punto de Aplicación de Políticas) debido a factores observables.

Separación de los planos

El plano de datos y el plano de control están lógicamente separados.

2.1 Arquitectura y Gobierno Zero Trust

Amenazas en ZTA

Una ZTA correctamente implementada y mantenida puede reducir el riesgo general y proteger contra las amenazas comunes. Sin embargo, algunas amenazas presentan características únicas al implementar una ZTA.

